CVE-2024-3094漏洞分析

周鹏程 | 2024-04-07 | Security

漏洞描述

xz是用于压缩/解压缩文件的一款压缩库，微软的安全研究员Andres Freund调查程序性能下降时发现了该漏洞，xz漏洞从5.6.0版本开始存在恶意后门，该后门存在于XZ Utils的5.6.0和5.6.1版本中，攻击者可能利用这一漏洞在受影响的系统上绕过SSH的认证获得未授权访问权限，执行任意代码。

openEuler的漏洞响应

- 2024年3月28日，openEuler初步感知到xz 5.6.0/5.6.1版本存在安全风险。立即发起了对openEuler 2203-LTS，2003-LTS各个发行分支，以及测试中的分支2403-LTS进行全量的软件版本排查，最后确认有缺陷的xz 5.6.0/5.6.1版本没有引入openEuler仓库。
- 2024年3月29日, openwall 披露了xz CVE-2024-3094的攻击代码和攻击手段。openEuler安全团队实时跟进，组织相关技术人员分析openEuler xz的源码是否存在恶意攻击代码，从源码代码层面确认了CVE-2024-3094漏洞不涉及openEuler xz软件。

漏洞背景

Jia Tan 是本次xz后门漏洞的攻击者，为了实现本次的xz软件的后门注入，JiaT75在xz代码和社会工程学上的设计可谓是处心积虑，印证了有句古话:"不怕贼偷，就怕贼惦记"。本文xz事件的关键节点信息梳理引用自:https://research.swtch.com/xz-timeline

Jia Tan成为xz社区maintainer

2021年10月26日 JiaTan第一次向xz开源社区贡献了代码，并开始活跃于xz的社区，在2021年Jia Tan共提交了546次代码，JiaTan提交表现为一名勤奋、高效的开源社区贡献者，并在此之后不断地对xz压缩库做出代码贡献。 2022年4月到6月 xz初始的维护人 Lasse Collin由于长期的心理健康问题以及其他原因，会定期退网一段时间进行调理。在2022年4月到6月之间，Lasse Collin陆续收到了Jigar Kumar，Dennis Ens等用户的施压邮件，邮件的内容大致是:质疑Lasse Collin是不是是去了对xz的维护兴趣？为什么没有及时合入JiaTan的贡献代码？以及让 Lasse Collin给予Jia Tan具有maintainer提交权限的心理暗示。其中部分内容展示如下：

存储库。为什么要等到5.4.0版本才换维护人？为什么要延迟你的存储库所需要的改变？”

- Dennis Ens:“我对你的心理健康问题感到遗憾，但是认识到自己的限制是非常重要的。我知道对于所有的参与者来说，这只是一个业余项目，但是社区需要更多。为什么不将C语言的XZ的维护权转交给其他人，这样你就可以更多地关注Java的XZ了呢？或者把Java的XZ的维护权转交给其他人，以便你可以专注于C语言的XZ？试图同时维护两者意味着两者都不能被很好地维护。”

2022-06-29 Lasse Collin回复到：“正如我在之前的邮件中暗示的，Jia Tan 可能会在未来在项目中扮演更大的角色。他已经在邮件列表之外大力帮助过我，现在实际上已经是一名共同维护者了。我知道在git存储库中还没有发生太大的事情，但是事情是在慢慢发生的。无论如何，维护权的一些变动已经在进行中，至少对于XZ Utils是这样。 “

基于Jia Tan在xz社区的贡献表现，社区用户Jigar Kumar和Dennis Ens等用户的邮件施压，还有Lasse Collin自身的身体健康原因，最终Lasse Collin给予了 Jia Tan在xz社区的 maintainer席位。事后Evan Boehs观察到，Jigar Kumar和Dennis Ens都未在互联网上的其他地方出现过，在Jia Tan成为社区maintainer后，Jigar Kumar和Dennis Ens也未在xz社区中使用邮件来沟通过任何其它问题，看起来它们很可能是为了促使Lasse赋予 Jia Tan 获得更多控制权而创建的伪造身份。这种策略起作用了。

Jia Tan攻击开始

2024-02-23: Jia Tan 将隐藏的后门二进制代码巧妙地隐藏在一些二进制测试输入文件中。README文件（从 Jia Tan 出现之前很久就已经存在）中已经提到，“这个目录包含了许多文件，用于测试解码器实现中对.xz、.lzma ，以及.lz 文件的处理。许多文件是手工使用十六进制编辑器创建的，因此没有比文件本身更好的‘源代码’。” 对于这种压缩软件的库来说，拥有这类被压缩的二进制测试文件是非常常见的。Jia Tan 利用这一点添加了一些不会被仔细审查的文件。 2024-02-24: Jia Tan 标记并构建了v5.6.0版本，并发布了包含额外恶意build-to-host.m4的xz-5.6.0.tar.gz发行版，该m4文件在构建deb/rpm包时添加了后门。这个m4文件在源代码仓库中不存在，但是在打包过程中还添加了许多其他合法的文件，所以它本身并不引起怀疑。但是这个脚本已经从通常的副本中被修改以添加后门。 2024-03-09: Jia Tan 标记并构建了v5.6.1版本，并发布了包含新后门的xz 5.6.1发行版。 2024-03-25: 很多用户在Debian社区中提出建议，要求xz-utils更新到5.6.1。就像在2022年Jia Tan成为xz社区maintainer之前的邮件压力活动中一样，出现了更多在之前互联网上不存在的邮件地址来倡导更新xz 5.6.1版本。 2024-03-28: Jia Tan 在Ubuntu中提出了一个bug，要求从Debian更新xz-utils到5.6.1。

攻击被检测到

2024-03-28: 微软的安全研究员Andres Freund调查程序性能下降时发现了该漏洞，私下通知了Debian和distros@openwall。 随后RedHat 分配了CVE-2024-3094。 2024-03-29 :CVE-2024-3094公开披露，CSSV漏洞评分10分，是一个满分漏洞，是第一起严重的、针对广泛使用的开源软件的供应链攻击。它标志着开源供应链安全的一个分水岭时刻。在此以后开源社区贡献者的真实身份验证以及二进制测试文件的审核可能会变得更为严苛，各大开源社区和操作系统发行商也会受到该事件的推动,进一步完善关于软件安全的运作规则。

漏洞代码触发分析

large_compressed.lzma来修改构建过程以构建出留有后门的动态库liblzma.so。由于SSH底层依赖了liblzma库，攻击者可能利用这一漏洞在受影响的系统上绕过SSH的认证获得未授权访问权限，执行任意代码。更多代码技术细节信息，请参见:xz攻击脚本演练帖子。

影响性分析

如果机器上装有涉及CVE-2024-3094缺陷的xz软件，远程攻击者能够通过SSH发送任意代码，造成远端任意代码执行，进而有效控制受害者的整台机器。

规避措施

无

解决方案

卸载/弃用xz 5.6.0/5.6.1缺陷版本，使用openEuler社区发行的xz稳定版本xz 5.2.5，或者其他社区的稳定版本。

本文参考链接

https://www.openwall.com/lists/oss-security/2024/03/29/4

https://gist.github.com/thesamesam/223949d5a074ebc3dce9ee78baad9e27

https://boehs.org/node/everything-i-know-about-the-xz-backdoor

https://tukaani.org/xz-backdoor/

https://research.swtch.com/xz-timeline

https://research.swtch.com/xz-script

【版权声明】Copyright © 2025 openEuler Community。本文由openEuler社区首发，欢迎遵照 CC-BY-SA 4.0 协议规定转载。转载时敬请在正文注明并保留原文链接和作者信息。

文仅供读者参考，由此产生的所有法律责任均由读者本人承担。

您向他人推荐 **openEuler社区** 的可能性有多大?

openEuler 是由开放原子开源基金会（OpenAtom Foundation）孵化及运营的开源项目

友情链接

木兰开源社区 鲲鹏社区 鲲鹏小智 鹏城实验室 infoQ 开源社 中科微澜 Authing openGauss 昇思MindSpore Ebaina openUBMC

品牌 隐私政策 法律声明 关于cookies

遵循 木兰宽松许可证第2版（MulanPSL2）

版权所有 © 2025 openEuler 保留一切权利

京ICP备2020036654号-1 京公网安备 11030102011597 号

contact@openeuler.io

openEuler小助手 openEuler公众号